

Bridging the Accuracy Gap: Witness-Cosigned Hash Chains for FDA-Compliant AI Agent Audit Trails

Straughter Guthrie
VAOS (vaos.sh)

April 4, 2026

Abstract

Hash-chained audit trails—as deployed in Certificate Transparency, Hyperledger Fabric, and AI agent governance systems such as vaos-kernel—provide strong tamper-evidence guarantees: append-only structure and collision-resistant chaining ensure that logged entries cannot be modified without detection. However, these mechanisms categorically cannot prove that logged actions *actually occurred*. In regulated settings governed by 21 CFR Part 11 and the ALCOA+ data-integrity framework, this “accuracy gap” is the difference between a technically correct audit log and a legallymissible record. We present a systematic classification of nine ALCOA+ attributes against hash-chained audit, identifying three tiers of guarantee strength. We then propose *witness cosigning*—an architectural extension where independent observers countersign agent actions before they are chained—and show that it elevates the Accurate property from Tier 3 (unenforceable by any audit log) to Tier 1 (cryptographically guaranteed under an (n, t) -threshold trust model). Quantitative analysis demonstrates that witness cosigning adds sub-millisecond overhead with a co-located hardware security module, negligible relative to the 622 ms Postgres write latency that dominates production deployments. We identify six specific gaps between current hash-chain implementations and 21 CFR Part 11, showing that witness cosigning resolves three of them. Finally, we compare our approach against Certificate Transparency, Trillian, Hyperledger Fabric, and W3C Verifiable Credentials, demonstrating that the accuracy gap is universal across all major append-only log systems.

1 Introduction

AI agents increasingly operate in regulated environments—pharmaceutical manufacturing, clinical trials, and medical device software—where every action must produce audit records compliant with FDA regulations. The ALCOA+ framework, codified in FDA guidance and referenced by 21 CFR Part 11, requires that records be **A**tttributable, **L**egible, **C**ontemporaneous, **O**riginal, **A**ccurate, **C**omplete, **C**onsistent, **E**nduring, and **A**vailable.

Hash-chained audit trails—where each entry’s identifier is computed as $H_n = \text{BLAKE2b}(\text{fields}_n \| H_{n-1})$ —provide tam-

per evidence by construction. Modifying any entry invalidates all subsequent hashes. This mechanism is deployed in Certificate Transparency (CT, RFC 6962/9162), Google’s Trillian, and AI governance systems such as vaos-kernel.

However, a fundamental limitation exists: *logging that action X occurred does not prove that X actually occurred*. We call this the **accuracy gap**. A database-level attacker who compromises the storage layer can reconstruct an entirely fabricated chain from the known genesis hash, producing an internally valid but factually false audit trail. No append-only log, regardless of its cryptographic sophistication, can close this gap alone.

This paper makes five contributions:

1. An honest, three-tier classification of all nine ALCOA+ attributes against hash-chained audit (Section 3).
2. A *witness cosigning protocol* that bridges the accuracy gap by requiring independent observers to countersign agent actions before chain inclusion (Section 4).
3. A quantitative overhead analysis showing that witness cosigning adds negligible latency relative to existing storage bottlenecks (Section 5).
4. A regulatory gap analysis mapping six specific deficiencies to 21 CFR Part 11 sections and identifying which are resolved by witness cosigning (Section 6).
5. A comparative analysis showing the accuracy gap is universal across CT, Trillian, Hyperledger Fabric, and W3C Verifiable Credentials (Section 7).

2 Background

2.1 ALCOA+ Framework

The ALCOA acronym (Attributable, Legible, Contemporaneous, Original, Accurate) was introduced by the FDA to describe data integrity requirements for regulated records. The “+” extension adds Complete, Consistent, Enduring, and Available. Together, the nine attributes define what constitutes trustworthy data under Good Practice (GxP) regulations [1].

2.2 21 CFR Part 11

Title 21, Code of Federal Regulations, Part 11 establishes FDA requirements for electronic records and electronic signatures. Subpart B (§§11.10–11.70) governs electronic records: controls for system access, audit trails, operational checks, and record retention. Subpart C (§§11.100–11.300) governs electronic signatures: uniqueness, identity verification, and the requirement for signatures to include two distinct identification components (§11.200).

2.3 Hash-Chained Audit in vaos-kernel

vaos-kernel implements a hash-chained audit ledger where each `AuditEntry` contains fields for `AgentID`, `Component`, `Action`, `Status`, `Details`, and a cryptographic chain hash. The `Record()` function computes:

$$H_n = \text{BLAKE2b-256}(\text{canonical_fields}_n \| H_{n-1})$$

where H_0 is the well-known genesis hash. The `VerifyChain()` function independently recomputes the chain to detect tampering. A 60-second intent-scoped JWT binds each entry to an authenticated agent identity.

Benchmarks show four operating configurations: baseline at 51,005 req/s (p99: 0.70 ms), synchronous ALCOA+ attestation at 50,774 req/s (p99: 1.69 ms), asynchronous attestation at 32,827 req/s (p99: 87.86 ms), and synchronous with Postgres persistence at 20,329 req/s (p99: 622 ms).

3 ALCOA+ Property Classification

We classify each ALCOA+ attribute into three tiers based on the strength of guarantee that a hash-chained audit trail provides.

- **Tier 1 — Cryptographically enforced.** Violation requires breaking a cryptographic assumption (collision resistance of BLAKE2b-256).
- **Tier 2 — Architecturally supported under trust assumptions.** The mechanism works correctly assuming specified components behave honestly.
- **Tier 3 — Unenforceable by audit log alone.** The property requires external validation beyond what any append-only log can provide.

Table 1 presents the complete classification.

3.1 The Database-Level Attacker

The classification reveals a critical vulnerability. A Tier B attacker—one who can read and write the Postgres `alcoa_actions` table directly—knows the genesis hash constant `vaos-kernel-genesis-00...00` and can rewrite the entire chain from scratch. Every recomputed hash will be internally consistent, producing a fabricated but

valid chain. Without an external anchor point (a chain hash published to a medium the attacker cannot modify), the hash chain provides tamper evidence only against application-level attackers who cannot access storage directly.

Certificate Transparency addresses this via Signed Tree Heads (STHs) gossiped across independent monitors. We argue that analogous external anchoring is necessary for regulated AI agent audit trails.

4 Witness Cosigning Protocol

We propose a witness cosigning protocol that modifies the `Record()` flow to require independent attestation before chain inclusion.

4.1 Protocol Specification

Let W denote the total number of registered witnesses and $T \leq W$ the required signature threshold.

1. **Intent Declaration.** The agent invokes `Record()` with all `AuditEntry` fields populated but no hash computed. The entry enters a “pending” state.
2. **Witness Dispatch.** The ledger dispatches `canonical_fieldsn` (deterministic JSON serialization of all entry fields except `Attestation` and `ID`) to each witness $w_i \in \{w_1, \dots, w_W\}$.
3. **Independent Verification.** Each witness w_i independently verifies the action occurred. The verification method is domain-specific:
 - *Human supervisor:* Reviews action details, authenticates via FIDO2/WebAuthn (possession factor + biometric/PIN).
 - *HSM/service:* Validates action against policy rules, signs with hardware-backed key.
 - *Sensor/PLC:* Provides independent measurement hash, signs with embedded key.
4. **Signature Return.** Each verifying witness returns:

$$\sigma_i = \text{Sign}_{w_i}(\text{canonical_fields}_n \| w_i.\text{id} \| \text{timestamp}_i)$$

5. **Threshold Aggregation.** The ledger collects signatures until $|\{\sigma_i\}| \geq T$, then sets:

$$\text{Attestation}_n = \text{Aggregate}(\sigma_{i_1}, \dots, \sigma_{i_K}), \quad K \geq T$$

where `Aggregate` produces a deterministic encoding sorted by witness ID.

6. **Chain Extension.** Only after threshold is met:

$$H_n = \text{BLAKE2b}(\text{canonical_fields}_n \| \text{Attestation}_n \| H_{n-1})$$

Table 1: ALCOA+ Property Classification Against Hash-Chained Audit

ALCOA+ Attribute	Tier	Mechanism	Trust Assumption
Attributable	2	AgentID + JWT <code>agent_id</code> claim	Credential private key not compromised
Legible	3	JSON serialization, SQL storage	Format migration over decades is organizational
Contemporaneous	2	<code>time.Now().UTC()</code> auto-stamp, 60s JWT TTL	Server clock is honest; no clock skew
Original	1	Append-only chain + <code>VerifyChain()</code>	Collision resistance of BLAKE2b-256
Accurate	3	Deterministic intent fingerprint	<i>None—logging X does not prove X occurred</i>
Complete	2	Details map + chain gap detection	<code>Record()</code> is the sole entry path
Consistent	1	Hash chain enforces strict ordering	Collision resistance of BLAKE2b-256
Enduring	2	Postgres DBWriter persistence	Correct backup/archival administration
Available	3	Single Postgres instance	Replication/HA infrastructure required

7. **External Anchoring.** H_n is published to one or more external media (RFC 3161 timestamp authority, independent log service, plant historian, or blockchain anchoring service), making Tier B chain reconstruction detectable.

If T signatures are not collected within the JWT validity period (60 s), the entry is discarded and the chain remains unmodified.

4.2 Security Game

We define a formal security game for (n, t) -threshold accuracy.

Game $\text{ACCURACY}_{\mathcal{A}, n, t}$:

1. *Setup.* Initialize ledger with genesis hash. Register n witnesses with key pairs (pk_i, sk_i) . Adversary $\mathcal{A}$ selects up to $t - 1$ witnesses to corrupt, receiving their secret keys.
2. *Challenge.* $\mathcal{A}$ submits an action to `Record()`. Honest witnesses verify against ground truth (provided by an oracle) and sign only if the action actually occurred. Corrupted witnesses sign or refuse arbitrarily.
3. *Win Condition.* $\mathcal{A}$ wins if the ledger accepts an entry where (a) the declared action did *not* actually occur and (b) the entry has $\geq T$ valid witness signatures.

Claim. For any PPT adversary $\mathcal{A}$ corrupting fewer than t witnesses:

$$\text{Adv}_{\mathcal{A}, n, t}^{\text{accuracy}} = \text{negl}(\lambda)$$

Proof sketch. If $\mathcal{A}$ wins, the entry has $\geq T$ valid signatures but $\mathcal{A}$ controls only $t - 1 < T$ witnesses. Therefore at least one honest witness’s signature appears on a false entry. Since honest witnesses only sign actions that actually occurred, this signature was forged, contradicting the EUF-CMA security of the signature scheme. $\square$

4.3 Domain Instantiations

Clinical Trial AI. A clinician operator countersigns via FIDO2/WebAuthn, satisfying §11.200’s two-component requirement (authenticator device + biometric/PIN). Threshold:

Table 2: Witness Cosigning Overhead Analysis

Configuration	p99 (ms)	Viability
Sync + ALCOA+ (baseline)	1.69	Baseline
+ 1 local witness (HSM)	~2.2	Real-time mfg.
+ 1 remote witness (same DC)	~12–50	Clinical trials
+ 3-of-5 threshold (fanout)	~60–80	Batch records
Sync + Postgres (baseline)	622	Binding constraint
+ 1 local witness + Postgres	~623	Witness negligible

1-of-1. External anchor: hospital EHR system stores chain hash in an immutable patient record.

Lab Automation. PLC/sensor systems with hardware-backed keys (TPM or secure element) provide independent measurement hashes. Threshold: configurable (e.g., 2-of-3 sensors for critical operations). External anchor: laboratory information management system (LIMS).

Pharmaceutical Manufacturing. DCS/SCADA systems countersign via HSM-backed Ed25519 or ECDSA signatures. Threshold: 1-of-1 for routine operations, 2-of-3 for batch release. External anchor: plant historian system (e.g., OSIsoft PI).

5 Overhead Analysis

Table 2 presents estimated p99 latencies for witness cosigning configurations, using vaos-kernel benchmarks as baseline.

The key finding is that witness cosigning adds sub-millisecond overhead with a co-located HSM witness (~0.5 ms), negligible compared to the 622 ms Postgres write latency that dominates production configurations. The protocol’s cost is dominated by network round-trip time to remote witnesses, not cryptographic operations. For pharmaceutical manufacturing where a plant-floor HSM is co-located, witness cosigning is effectively free relative to existing storage constraints.

Cryptographic overhead per witness signature is approximately 50–100 μs for Ed25519 signing and 70–150 μs for verification. BLAKE2b-256 hashing over the extended payload (canonical fields + attestation) adds less than 10 μs for pay-

loads under 10 KB. For a T -of- W threshold with parallel dispatch, latency is dominated by the T -th fastest witness response plus aggregation time.

For the in-memory synchronous configuration at 50,774 req/s, adding a 0.6 ms local witness reduces throughput to approximately 47,000 req/s ($\sim 7\%$ reduction). For the Postgres-backed configuration at 20,329 req/s, the throughput impact is negligible ($\sim 0.1\%$ reduction).

6 Regulatory Gap Analysis

We identify six specific gaps between vaos-kernel (and IETF draft-goswami-agent-jwt-00) and 21 CFR Part 11 / EU Annex 11. Table 3 summarizes each gap and whether witness cosigning resolves it.

6.1 Gaps Resolved by Witness Cosigning

Signature Meaning (§11.50). 21 CFR §11.50 requires that electronic signatures include the printed name of the signer, the date and time of signing, and the meaning associated with the signature (e.g., “review,” “approval,” “responsibility”). vaos-kernel’s intent fingerprint encodes *what* action was taken but does not attach human semantic meaning. Witness cosigning by a clinician or operator, who explicitly approves the action via FIDO2 authentication, attaches the required meaning to the attestation.

Electronic Signature Definition (§11.70). The intent fingerprint computed by vaos-kernel is a cryptographic hash of action parameters—not an electronic signature under FDA’s definition. A FIDO2 assertion produced by a human witness constitutes an electronic signature: it is linked to a specific individual, is under that individual’s sole control, and cannot be reused.

Two-Component Authentication (§11.200). 21 CFR §11.200(a) requires electronic signatures to employ at least two distinct identification components (e.g., an identification code and a password). FIDO2/WebAuthn satisfies this with a hardware authenticator (something you have) and a biometric or PIN (something you are/know).

6.2 Compliance Roadmap

For practitioners deploying AI agents in GxP environments, we recommend the following sequence:

1. **Deploy witness cosigning** to resolve gaps 4–6 (signature requirements).
2. **Implement archival storage** to partially resolve gap 3 (retention).
3. **Build export pipeline** to resolve gap 2 (standard format export).
4. **Establish validation lifecycle** (SOPs, IQ/OQ/PQ documentation) to resolve gap 1.

7 Comparison with Related Systems

Table 4 compares ALCOA+ tier classifications across five systems.

Certificate Transparency (RFC 6962/9162) uses Merkle tree heads gossiped across independent monitors for tamper detection. Monitors detect log misissuance but do not *attest* that certificates were legitimately issued—they only verify log inclusion. Witness cosigning provides a stronger guarantee: active attestation of accuracy, not passive monitoring of consistency.

Trillian provides sparse Merkle trees with efficient inclusion proofs but no mechanism for third-party action attestation. The accuracy gap exists identically.

Hyperledger Fabric endorsement policies require specified peers to sign transactions before commitment—architecturally the closest analog to witness cosigning. However, Fabric endorsement validates business logic conformance, not regulatory data integrity. We argue that Fabric endorsement policies could be adapted for ALCOA+ compliance by requiring endorsement from peers in GxP-validated environments with HSM-backed keys.

W3C Verifiable Credentials and C2PA address provenance and authenticity for digital identity and media but do not engage with ALCOA+ or FDA regulatory requirements. Neither specification references 21 CFR Part 11 in its normative text.

The comparison demonstrates that the accuracy gap is a shared limitation across all major append-only log systems, and witness cosigning is a generalizable solution.

8 Conclusions

This paper identifies the accuracy gap—the inability of hash-chained audit trails to prove that logged actions actually occurred—as a fundamental barrier to FDA compliance for AI agent systems. We provide the first systematic classification of ALCOA+ attributes against hash-chained audit, revealing that only two of nine attributes (Original, Consistent) achieve Tier 1 cryptographic guarantees, while the critical Accurate property is Tier 3: unenforceable by any audit log alone.

Our witness cosigning protocol addresses this gap by requiring T -of- W independent observers to countersign agent actions before chain inclusion. The witness signatures are incorporated into the hash input, making cosigning a Tier 1 property of the resulting chain. Under an (n, t) -threshold trust model, accuracy holds unless $\geq t$ witnesses are compromised—a reduction to EUF-CMA signature unforgeability.

Quantitative analysis shows that the protocol adds sub-millisecond overhead with co-located hardware witnesses, negligible relative to the storage latency that dominates production deployments. Of six identified regulatory gaps against 21 CFR Part 11, witness cosigning resolves three (signature meaning, electronic signature definition, and two-component authentication).

The accuracy gap is universal: Certificate Transparency,

Table 3: Regulatory Gap Analysis: vaos-kernel vs. 21 CFR Part 11

Gap	CFR Reference	Resolved by Witness Cosigning?	Category
No validation lifecycle documentation	§11.10(a)	No	Organizational
No export-to-standard-format mechanism	§11.10(b)	No	Engineering
60s JWT $\neq$ full retention period	§11.10(c)	Partially (chain provides integrity)	Engineering
No signature meaning attribution	§11.50	Yes — witness attaches human meaning	Protocol
Intent fingerprint $\neq$ electronic signature	§11.70	Yes — FIDO2 satisfies signature definition	Protocol
No two-component signing	§11.200	Yes — FIDO2 provides possession + biometric	Protocol

Table 4: Cross-System ALCOA+ Comparison (Tier 1 = cryptographic, 2 = trust-dependent, 3 = unenforceable, – = N/A)

Property	vaos-kernel	CT/Trillian	Hyperledger	W3C VC	C2PA	+ Witness Cosigning
Attributable	2	2	2	2	2	2
Legible	3	3	3	3	3	3
Contemporaneous	2	2	2	2	2	2
Original	1	1	1	2	2	1
Accurate	3	3	3	3	3	1*
Complete	2	2	2	2	2	2
Consistent	1	1	1	–	–	1
Enduring	2	2	2	2	2	2
Available	3	2	2	3	3	2
External anchor	No	Yes	Yes	No	No	Yes

*Tier 1 under (n, t) -threshold trust: accuracy holds if fewer than t witnesses are compromised.

Trillian, Hyperledger Fabric, W3C Verifiable Credentials, and C2PA all share this limitation. Witness cosigning is the first mechanism to elevate the Accurate property to Tier 1 under explicit trust assumptions, bridging the gap between technically correct audit logs and legally submissible records.

References

- [1] U.S. Food and Drug Administration, “Guidance for Industry: Data Integrity and Compliance With Drug CGMP,” Apr. 2016.
- [2] U.S. Code of Federal Regulations, “Title 21, Part 11: Electronic Records; Electronic Signatures,” 2024.
- [3] B. Laurie, A. Langley, and E. Kasper, “Certificate Transparency,” RFC 6962, Jun. 2013.
- [4] B. Laurie, E. Messeri, and R. Stradling, “Certificate Transparency Version 2.0,” RFC 9162, Dec. 2021.
- [5] Google, “Trillian: General Transparency,” <https://github.com/google/trillian>, 2024.
- [6] Hyperledger Foundation, “Hyperledger Fabric Documentation v2.5,” <https://hyperledger-fabric.readthedocs.io>, 2024.
- [7] M. Sporny, D. Longley, and D. Chadwick, “Verifiable Credentials Data Model v2.0,” W3C Recommendation, Mar. 2024.
- [8] Coalition for Content Provenance and Authenticity, “C2PA Specification v2.0,” 2024.
- [9] J.-P. Aumasson, S. Neves, Z. Wilcox-O’Hearn, and C. Winnerlein, “BLAKE2: Simpler, Smaller, Fast as MD5,” in *ACNS*, 2013.
- [10] FIDO Alliance, “FIDO2: Web Authentication (WebAuthn),” W3C Recommendation, 2021.
- [11] C. Adams, P. Cain, D. Pinkas, and R. Zuccherato, “Internet X.509 PKI Time-Stamp Protocol (TSP),” RFC 3161, Aug. 2001.
- [12] A. Goswami, “Agentic JWT: Intent-Scoped Credentials for Autonomous AI Agents,” IETF Internet-Draft draft-goswami-agentic-jwt-00, 2024.